5 Cookies and response headers

This chapter covers

- Including cookies with requests
- Understanding how client and server settings interact to control cookie behavior
- Exposing response headers to clients

Chapter 4 introduced the concept of preflight requests. Preflight requests enable the browser to ask for the server's permission before making requests with certain HTTP methods and headers. This permissions model puts the server in charge of how cross-origin requests behave.

In the same way, there are additional features that also require special permissions in CORS. The first is user credential support. By default, CORS doesn't attach user credentials, such as cookies, on requests. The second is response headers support. The browser doesn't reveal all response headers to the client code. If your server responds with an X-Powered-By response header, the JavaScript client code won't be able to read its value without permission.

Luckily CORS has ways to support these features. As with all the other CORS features you've learned about, the server is in charge of enabling them, and it does so by using HTTP headers. This chapter will introduce two new response headers: